S.O.F.T. (Student Org Financial Threat Model)

Dhruv Guda

10/14/2026

S.O.F.T. (Student Org Financial Threat Model)

S.O.F.T. (Student Org Financial Threat Model) is a threat modeling framework designed to evaluate security threats to Flywire and SOFC financial accounts used by student organizations. Traditional threat modeling frameworks present key shortcomings when applied to student organization finances: PASTA treats evaluating threats as a single stage, requiring separate categorization to rank high-volume threats by risk; LINDDUN focuses primarily on privacy threats; and STRIDE addresses only specific threat categories within its acronym, potentially missing domain-specific financial risks.

Threat Model

Stage 1: Threat Categorization (The Sorting Hat)

When an organization audits their financial workflow, vulnerabilities are immediately sorted into one of four primary buckets:

- **Spoofing + Identity Fraud:** Evaluates threats like malicious actors impersonating signature-card holders. Emerging Threat Integration includes the use of generative AI to create highly convincing deepfake audio or tone-matched spear-phishing emails to authorize fraudulent Flywire requests.
- **Over-Privilege + Operational Exploitation:** Evaluates the abuse of valid credentials or loosely defined hierarchies (e.g., an outgoing treasurer retaining Flywire portal access after graduation).
- **Financial Data Interception + Tampering:** Evaluates the compromise of forms in transit. Privacy Integration recognizes that intercepted e-checks contain Student UINs and bank details, representing both a financial loss and a severe Personally Identifiable Information (PII) breach.

- **Transaction Hijacking + Non-Repudiation Failures:** Evaluates altering the destination of funds (e.g., changing a direct deposit routing number) or officers denying they authorized a transaction due to the use of shared generic logins (e.g., treasurer@studentorg.edu).

Stage 2 & 3: Risk Assessment + Risk Triage

Once a threat is categorized, Risk Assessment and Risk Triage utilize a 4x4 evaluation framework:

- **Assessment (The 4x4 Matrix):** The vulnerability is plotted on a 4x4 matrix evaluating Likelihood (Rare, Unlikely, Possible, Probable) against Impact (Negligible, Marginal, Critical, Catastrophic).
- **Triage:** The 4x4 matrix directly dictates priority. Threats landing in the "Probable/Critical" quadrants (like AI spear-phishing against inexperienced officers) are flagged to be fixed immediately, while "Rare/Negligible" threats are pushed down the list.

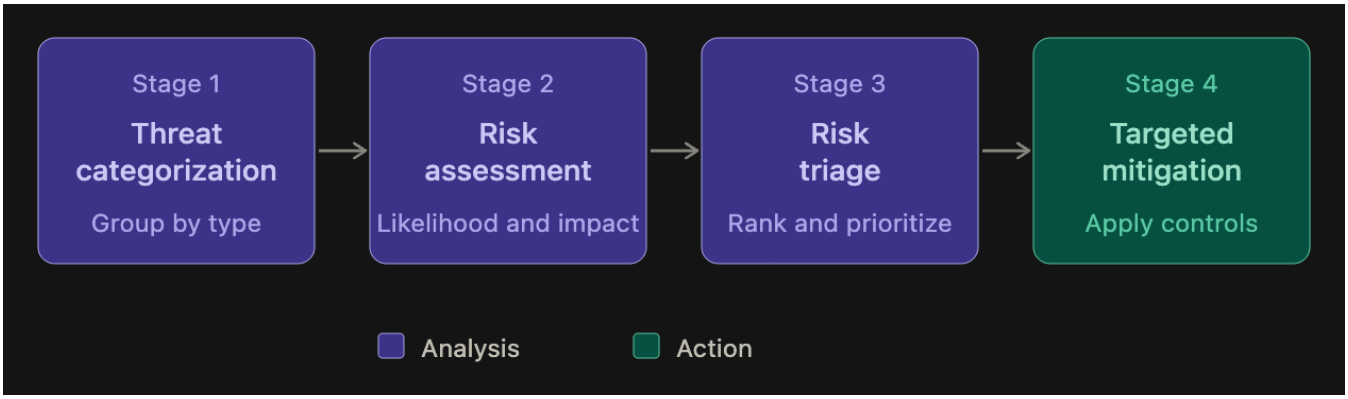
Stage 4: Targeted Mitigation (Applying the Fix)

The mitigation strategy is directly determined by the category assigned in Stage 1 and the risk score from Stages 2 and 3:

- **For Spoofing + Identity Fraud:** Mitigations must be verification-based (e.g., requiring a phone call or in-person confirmation for digital invoices over a certain dollar amount to bypass AI deepfakes).
- **For Over-Privilege + Operational Exploitation:** Mitigations must be access-based (e.g., mandatory access-revocation checklists at the end of every semester).

- **For Financial Data Interception + Tampering:** Mitigations must be encryption-based (e.g., using secure university portals to upload documents instead of emailing PDFs).
- **For Transaction Hijacking + Non-Repudiation:** Mitigations must be authentication-based (e.g., banning shared generic emails and requiring officers to use individual Single Sign-On accounts).

Visual Workflow



Results

Most threat models live in the theoretical realm of software architecture. S.O.F.T. takes established cybersecurity principles and applies them to a highly relevant, real-world vulnerability surface right here on campus: student organization finances. It provides a tailored solution for securing Flywire and SOFC accounts against attacks and exploits happening to student organizations today.

Distinctive Features

S.O.F.T. possesses key distinctive features that differentiate it from existing frameworks:

- Focused specifically on threats to Flywire and SOFC that impact organizational finances.

- Combines the specificity of STRIDE with the structured analysis process of PASTA.
- Integrates seamlessly with other threat and risk modeling frameworks by employing standard 4x4 risk matrices.

Discussion

Scenario Analysis

Event: An actor fills out an e-check request for reimbursement through publicly available SOFC forms and social engineering. The account numbers and signature card contacts are not publicly listed but may be easily found through social engineering. A malicious actor may submit e-check requests for fake purchases, increase the value of a legitimate request, or request reimbursement for a purchase a different actor made. While there are safeguards in place to prevent a threat like this from affecting organization funds, proper social engineering techniques may allow an individual to bypass those checks.

Weaknesses: This model allows student organizations to have a threat model designed specifically around the risks associated with operating an account on Flywire or through SOFC. Any application outside this narrow window is out of scope and would not be effective. These weaknesses should not be revised away, since the advantage of the model is that it is tailor-made for TAMU student organizations.

Shortcomings

Scope Limitation: S.O.F.T. is heavily optimized for business logic and financial workflows, lacking coverage for traditional network-level or infrastructure attacks.

Insider Threat: The model covers over-privilege but does not account for a fully authorized, legitimate credential holder acting maliciously.

Innovation and Tradeoffs

The primary innovation of this threat model is applying threat and risk analysis processes to the specific use case of student organizations at Texas A&M University. The primary tradeoff is the reduced scope of such a narrowly defined and specifically designed model.